

The background of the slide is a photograph of a modern university building with large glass windows and a white facade. In the foreground, there is a green field with many yellow dandelions. The sky is blue with a few white clouds.

5CM512

Communication and Security Protocols

Week 08:
Key Distribution
and
Public-Key Infrastructure (PKI)

KEY DISTRIBUTION USING ASYMMETRIC ENCRYPTION

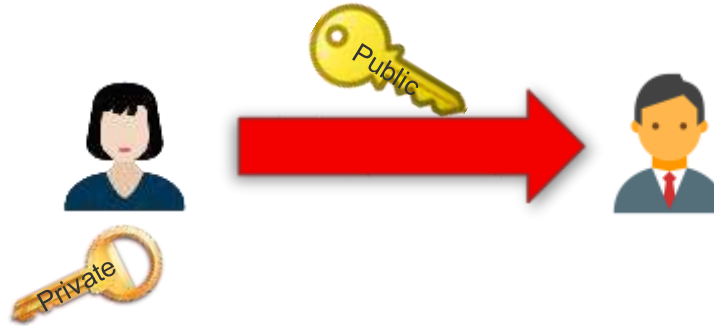
- What is the major role of public-key encryption ?
 - Address the problem of key distribution



- Two distinct aspects to the use of public-key encryption
 - The distribution of public keys
 - The use of public-key encryption to distribute secret keys

CLASS DISCUSSION

- Public key is public.



- What is the weakness?
 - Anyone can forge such as a public announcement.

PUBLIC-KEY CERTIFICATE

- **SOLUTION** : Public-key certificate
 - Public key + user ID of the key owner
 - The whole block is signed by a trusted third party
- Third party → Certificate authority (CA)
 - trusted by the user community
 - a government agency
 - a financial institution



- Bob : “Public key” → CA
CA : “Certificate” → Bob
- Bob : “Certificate” → Public
- Alice : Obtain Bob’s “Certificate” from Public and verify it

PUBLIC-KEY CERTIFICATE

- Process

PUBLIC KEY DISTRIBUTION OF SECRET KEYS

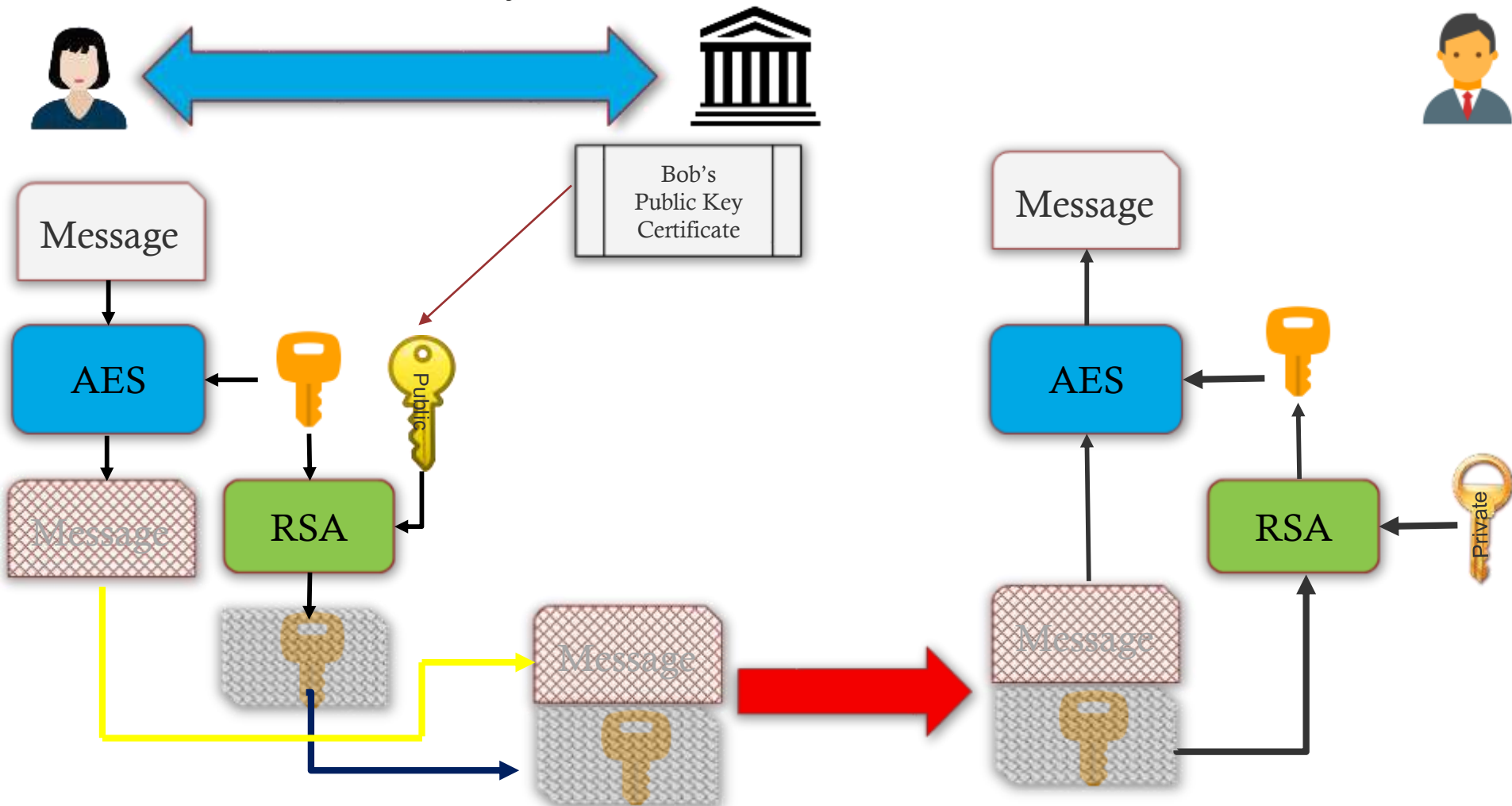
- Key exchange problem in Symmetric Encryption



- What is a possible solution we have already discussed ?
 - Diffie-Hellman key exchange
- What is the problem in Diffie-Hellman key exchange ?
 - No authentication between two parties
 - Man-in-the-Middle attack

PUBLIC KEY DISTRIBUTION OF SECRET KEYS

- Solution : Public Key Certificates

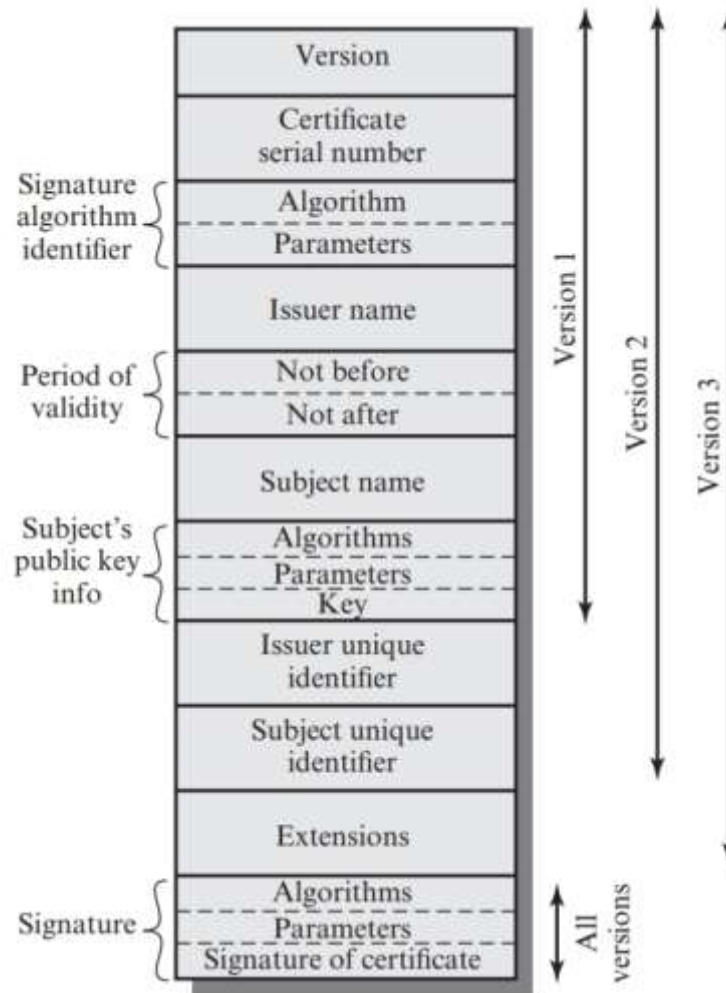


X.509 CERTIFICATES

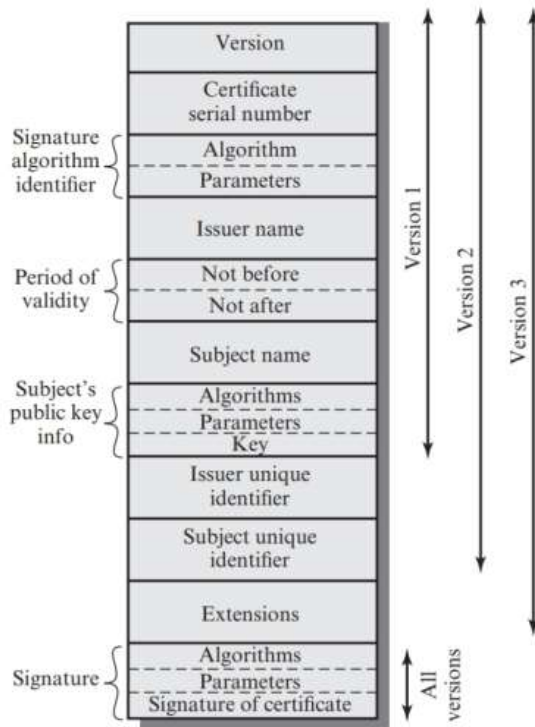
- Part of the X.500 series of ITU-T recommendations
 - X.500 defines a directory service
 - Database of information about the users
- Defines a framework for the provision of authentication services by the X.500 directory to its users
- Repository of public-key certificates
- Defines alternative authentication protocols based on the use of public-key certificates
 - Was initially issued in 1988
 - Based on the use of public-key cryptography and digital signatures
- The standard does not dictate the use of a specific algorithm but recommends RSA
- Used in most network security applications
 - IP Security, Secure Socket Layer (SSL), S/MIME

CLASS DISCUSSION

- Discuss the structure of the X.509 certificate



CLASS DISCUSSION



- **Serial number** : unique integer number for this certificate within CA
- **Signature algorithm identifier** : the algorithm used to sign the certificate
- **Issuer Name** : X.500 name of CA
- **Subject Name** : User name
- **Public key Info** : The public key of the user and the algorithm for which the key is to be used.
- **Issuer/Subject unique Identifier**: Optional bit string used to identify uniquely CA/user when X.500 name has been used for different entities.
- **Extensions**: Used in Version 3
- **Signature** : covers all the other fields of the certificate.

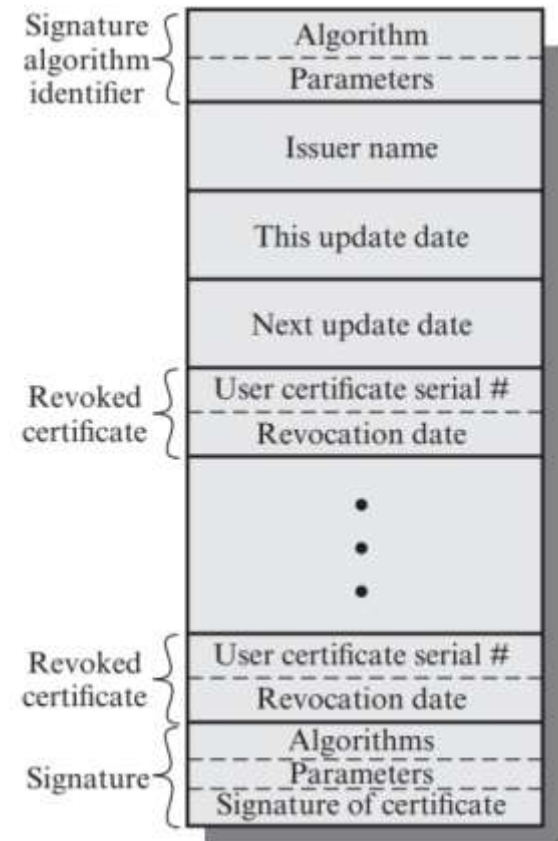
OBTAINING A USER'S CERTIFICATE

- Characteristics of user certificates :
 - Any user with access to the public key of the CA can verify the user public key that was certified
 - No party other than the certification authority can modify the certificate without this being detected
- Because certificates are unforgeable, they can be placed in a directory without the need for the directory to make special efforts to protect them



REVOCATION OF CERTIFICATES

- Period of validity
- New certificate just before the old one
- Revoke a certificate before it expires
 - The user's private key is assumed to be compromised
 - The user is no longer certified by this CA; reasons for this include subject's name has changed, the certificate is superseded, or the certificate was not issued in conformance with the CA's policies
 - The CA's certificate is assumed to be compromised
- Certificate Revocation List
 - User must determine whether the certificate has been revoked

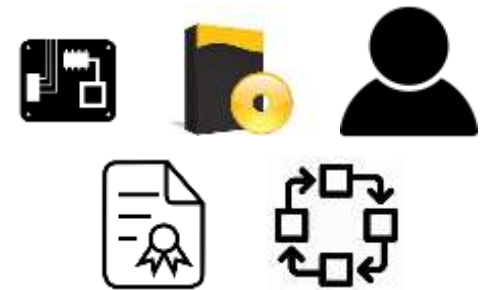


Any Questions?

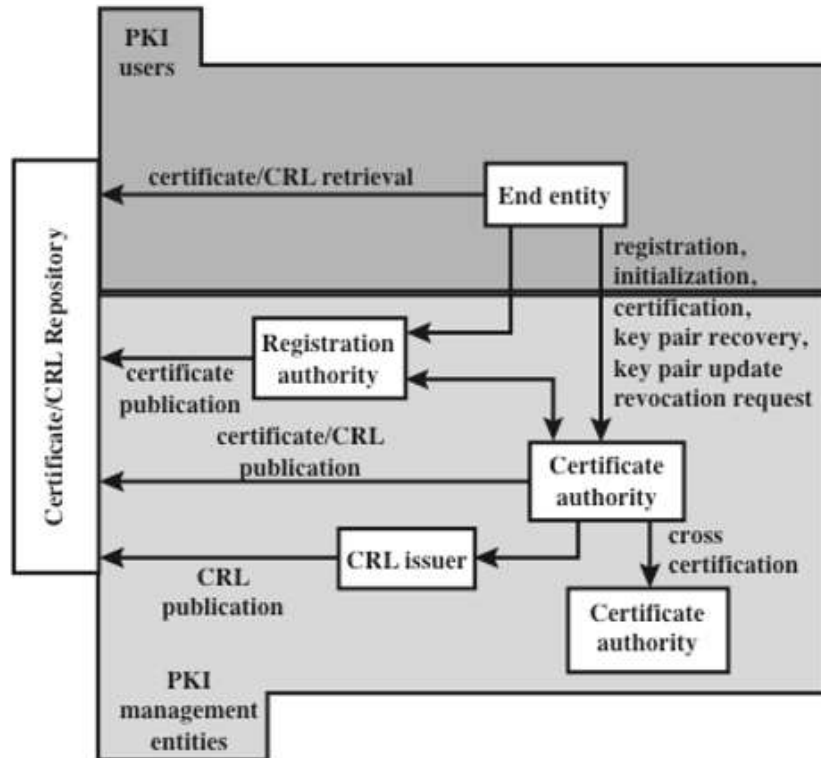


PUBLIC-KEY INFRASTRUCTURE

- The set of hardware, software, people, policies, and procedures
 - Create
 - Manage
 - Store
 - Distribute
 - Revoke Digital Certificates
 - based on asymmetric cryptography.
- The Internet Engineering Task Force (IETF) **Public Key Infrastructure X.509 (PKIX)** working group
 - Setting up a formal (and generic) model based on X.509
 - Suitable for deploying a certificate-based architecture on the Internet.

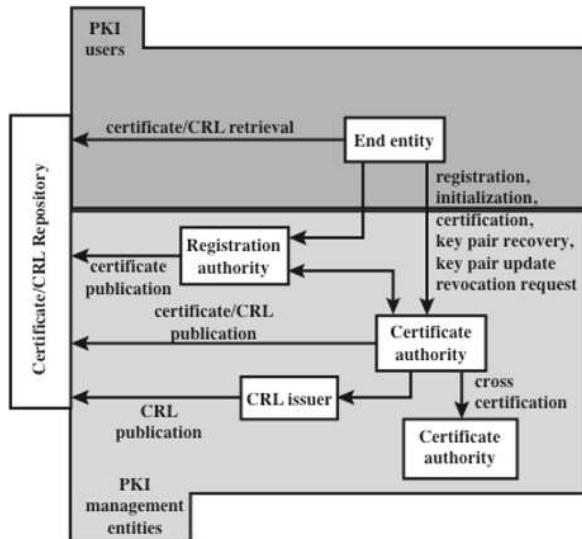


ELEMENTS OF THE PKIX MODEL



- End entity
- Certification authority (CA)
- Registration authority (RA)
- Certificate Revocation Lists (CRL) issuer
- Repository

PKIX MANAGEMENT FUNCTIONS



- Functions that potentially need to be supported by management protocols:

- Registration
- Initialization
- Certification
- Key pair recovery
- Key pair update
- Revocation request
- Cross certification

PKIX CERTIFICATE MANAGEMENT PROTOCOLS

- Alternative management protocols
 - **Certificate Management Protocols (CMP)**
 - Designed to be a flexible protocol able to accommodate a variety of technical, operational, and business models
 - **Certificate Management messages over Cryptographic message syntax (CMC)**
 - Is built on earlier work and is intended to leverage existing implementations



FEDERATED IDENTITY MANAGEMENT (FIM)

- Enterprise wide access to resources
 - By employees and other authorized individuals
 - Centralized and automated approach
- Defining an identity for each user (human or process)
- Associating attributes with the identity
- Enforcing a means by which a user can verify identity
- Central concept
 - Use of single sign-on (SSO)
 - Enables a user to access all network resources after a single authentication



CLASS DISCUSSION



- Discuss what principal elements of an identity management system

CLASS DISCUSSION



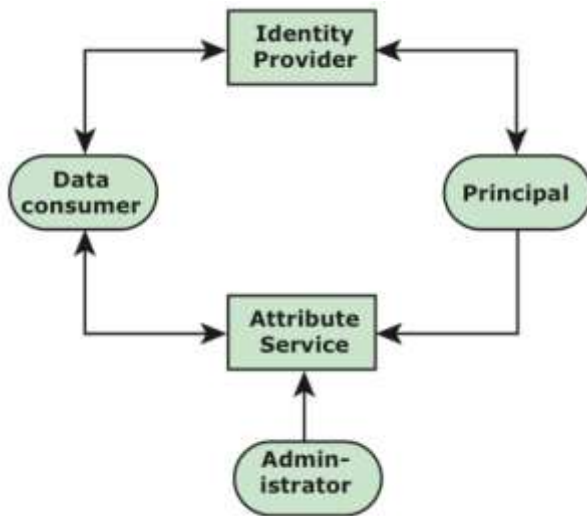
- Authentication
- Authorization
- Accounting
- Provisioning
- Workflow automation
- Delegated administration
- Password synchronization
- Self-service password reset
- Federation

SERVICES PROVIDED BY A FIM

- Typical services provided by a federated identity management system :
 - Point of contact
 - SSO protocol services
 - Trust services
 - Key services
 - Identity services
 - Authorization
 - Provisioning
 - Management



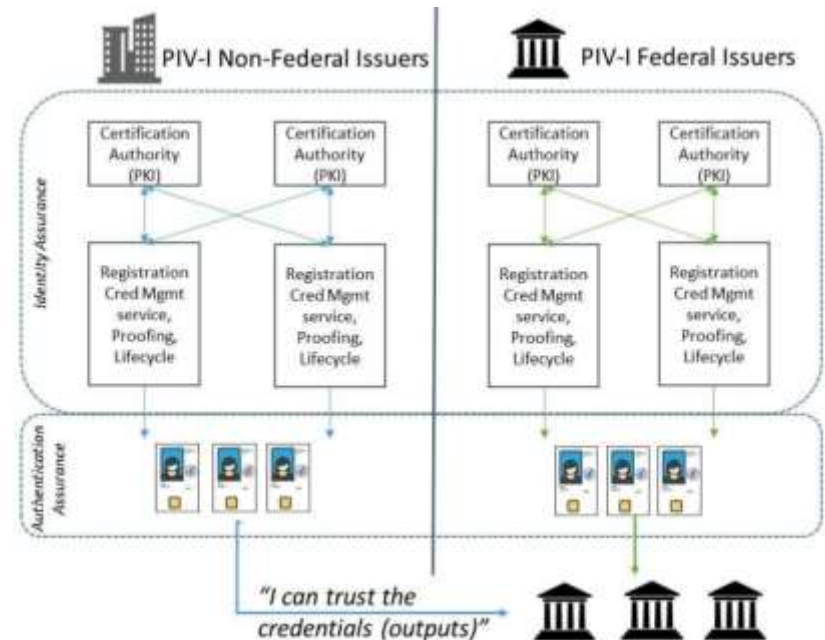
GENERIC IDENTITY MANAGEMENT SYSTEM



- **Principal**
 - Identity holder
 - Human user, user devices, agent processes, server systems etc.
- **Identity provider**
 - associates authentication information with a principal as well as attributes and one or more identifiers
 - passwords and biometric information.
- **Attribute service**
 - manages the creation and maintenance of attributes
- **Administrators**
 - assign attributes to users.
 - Roles, access permissions, and employee information
- **Data Consumers**
 - Entities that obtain and use data
 - Maintained and provided by identity and attribute provides

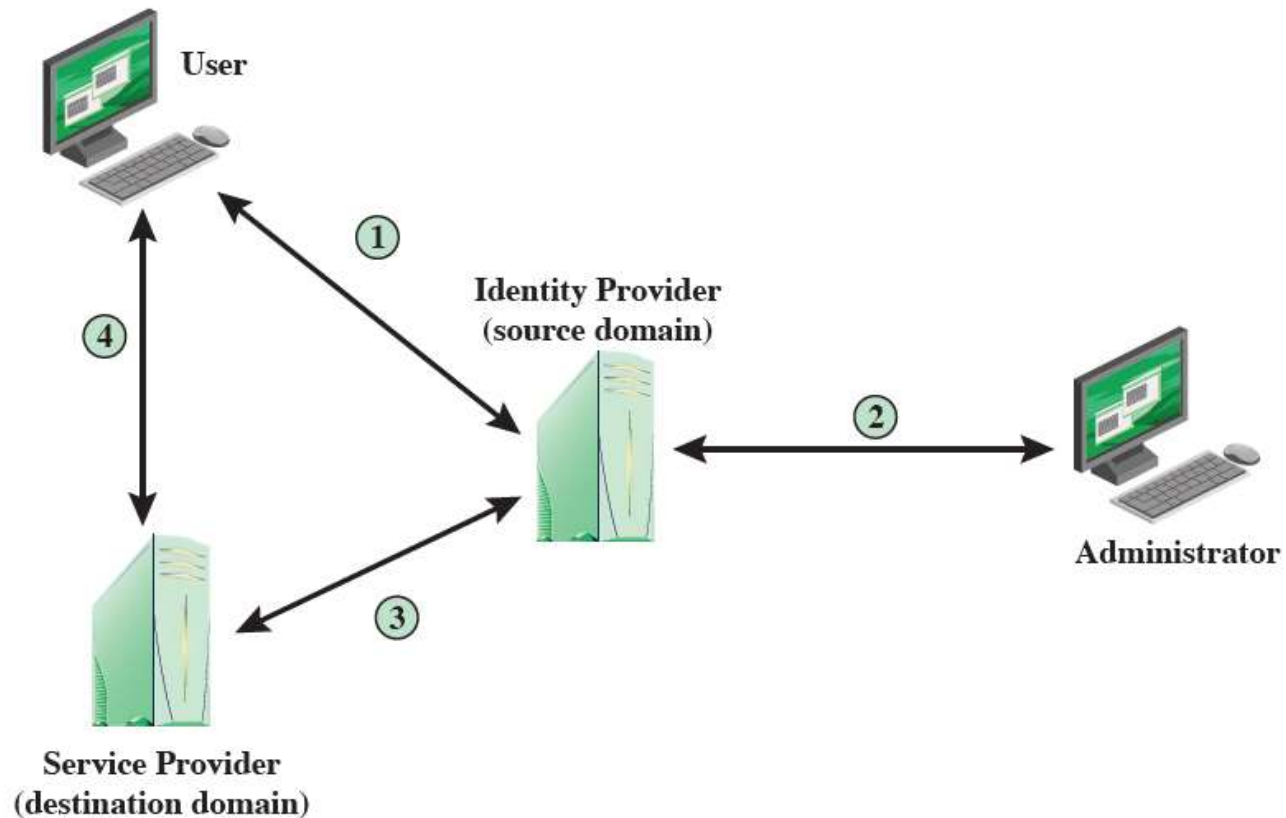
IDENTITY FEDERATION

- Identity federation
 - an extension of identity management to multiple security domains
- Federated identity management
 - Agreements, standards, and technologies
 - across multiple enterprises and numerous applications
 - Supports many thousands, even millions, of users
- Identity mapping
 - The federated identity management protocols map identities and attributes of a user in one domain to the requirements of another domain

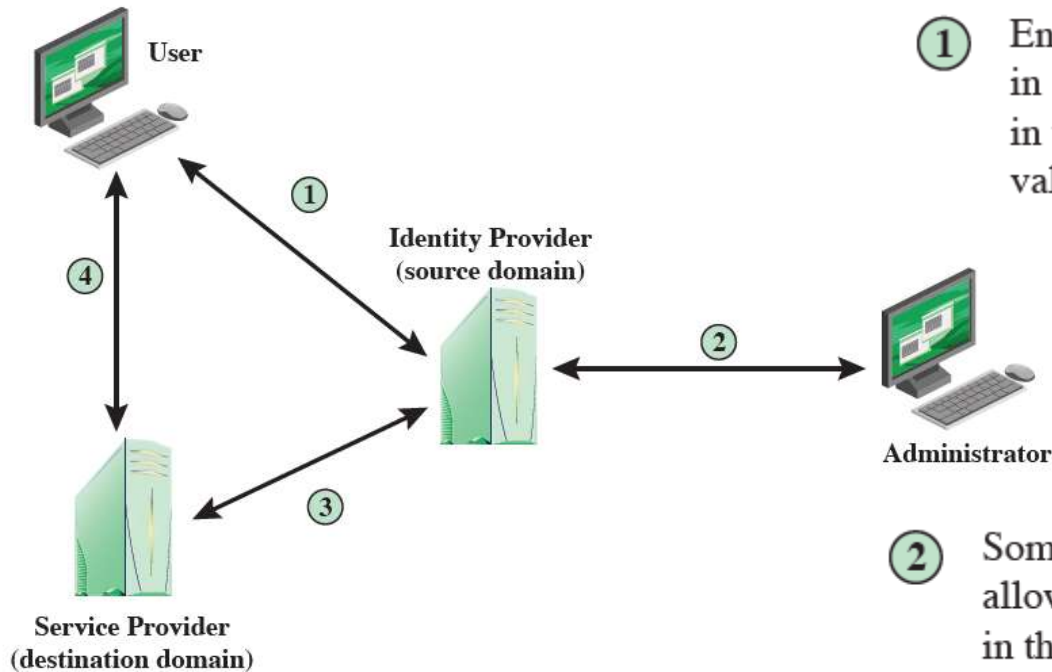


CLASS DISCUSSION

- Considering the following architecture, discuss the 4 steps in Federated Identity Operation



CLASS DISCUSSION



① End user's browser or other application engages in an authentication dialogue with identity provider in the same domain. End user also provides attribute values associated with user's identity.

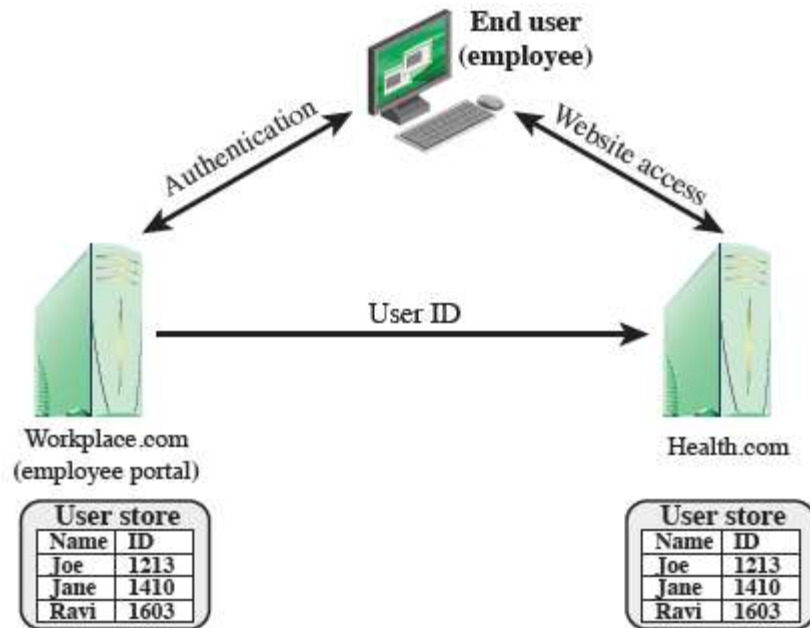
② Some attributes associated with an identity, such as allowable roles, may be provided by an administrator in the same domain.

③ A service provider in a remote domain, which the user wishes to access, obtains identity information, authentication information, and associated attributes from the identity provider in the source domain.

④ Service provider opens session with remote user and enforces access control restrictions based on user's identity and attributes.

EXAMPLE

FEDERATION BASED ON ACCOUNT LINKING



- Workplace.com → Health.com
 - provides employee health benefits.
- Employee → Workplace.com
 - Signs on to Workplace.com
 - Access authorized services and resources at Workplace.com.
- Employee → Health.com
 - Clicks on a link to access health benefits
 - Browser is redirected to Health.com
 - At the same time, the Workplace.com software passes the user's identifier to Health.com in a secure manner.
- The two organizations are part of a federation that cooperatively exchanges user identifiers.
 - Health.com maintains user identities for every employee at Workplace.com and associates with each identity health-benefits information and access rights.
- Linkage between the two companies : Based on account information
- User participation : Based on browser

Any Questions?

